

PHYSICAL SECURITY POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Physical Security Policy
Document ID	POL-PHY-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criterion CC6.4, and HIPAA Security Rule 45 CFR §164.310. Physical and environmental controls are carved out to AWS; what remains is home and client-site working.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 NO COMPANY FACILITY	6
6 WORKING FROM HOME	6
7 DEVICES AWAY FROM HOME.....	6
8 AT CLIENT PREMISES	7
9 RECORDS.....	7
10 EXCEPTIONS.....	7
11 REFERENCE.....	7
12 DOCUMENT POLICY HISTORY.....	7

1 Overview and Purpose

PromptHalo Technologies (“the Company”) has no premises. It processes nothing on hardware it owns in a building it controls, so most of what a physical security policy normally covers does not apply here.

What does apply is two things: the assurance the Company relies on from AWS, and how people work from home and at client sites.

2 Scope

This Policy covers the physical aspects of Company and client information handling wherever it happens — homes, client premises and shared spaces — and the carve-out of data center controls to AWS.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Carve-out** — the treatment of a subservice organization’s controls as outside the Company's description, relying on that organization’s own assurance.
3. **Clear desk** — leaving no Company or client information visible or accessible when the working area is unattended.
4. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
5. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
6. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
7. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]

8. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
9. **Security Officer** — the individual accountable for day-to-day operation of the security program.
10. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
11. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 No Company Facility

1. The Company operates a small office from which personnel may access or process Company or client information. Physical security measures are proportionate to the nature of the office, the information handled there, and the Company's size. Additional facilities used for Company operations shall be assessed and approved as appropriate. [SOC 2: CC6.4]
2. Physical and environmental controls for cloud infrastructure are provided by AWS and are addressed through the Company's third-party risk management process. AWS assurance documentation is reviewed periodically, as applicable, together with relevant complementary user entity controls for which the Company is responsible. [SOC 2: CC6.4, CC9.2]

6 Working From Home

1. The working area protects screens, printed material and conversations from observation by people outside the Company. In practice this means positioning a screen away from a window or a shared room and not taking client calls where they can be overheard. [SOC 2: CC6.4 • HIPAA §164.310(b)]
2. Screens lock automatically when unattended, and devices are not left unattended in public. [SOC 2: CC6.4]
3. Printing Company or client information is avoided. Where it happens, the paper is destroyed afterwards rather than kept. [SOC 2: CC6.4, CC6.5]
4. These expectations are acknowledged in the annual Code of Conduct acknowledgment rather than separately. [SOC 2: CC1.4, CC6.4]

7 Devices Away from Home

Most physical risk to the Company is a laptop in a public place, not an intruder in a building.

1. A device is not left unattended in a public space, a vehicle or checked baggage. In a shared or public setting, the screen is positioned so it cannot be read by the person behind you, and client calls are not taken where they can be overheard. [SOC 2: CC6.4 • HIPAA §164.310(b)]
2. Loss or theft of any device used for Company work is reported to the Security Officer within a day, under the Incident Response Policy. Because information lives in the Company's cloud

services rather than on the device, the response is to revoke access rather than to recover the hardware. [SOC 2: CC6.4, CC7.4]

3. Company-provided equipment is returned at the end of an engagement and sanitized before reissue, with the action recorded in the disposal register. [SOC 2: CC6.5]

8 At Client Premises

1. Personnel comply with the client's site rules, sign in as required, and do not attempt access beyond what the engagement authorizes. [SOC 2: CC6.4]
2. Client badges, keys and access cards are treated as Restricted, not left in bags or cars, and returned at the end of the engagement with the return recorded. [SOC 2: CC6.4, CC6.5]

9 Records

1. The AWS assurance report and the recorded complementary user entity controls. [SOC 2: CC6.4]
2. Annual acknowledgment covering the home working expectations. [SOC 2: CC1.4]
3. Records of client badge or key return. [SOC 2: CC6.4]

10 Exceptions

Where a person cannot meet a requirement of this Policy — a shared living space that cannot be made private, for instance — the position is recorded with the compensating measure, such as restricting the work that may be done there. Where no exceptions are in force, that is recorded affirmatively at the annual review.

11 Reference

1. SOC 2 Trust Services Criteria, Security category [CC6.4, CC6.5, CC9.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. POL-COC-001 Code of Conduct [SOC 2: CC1.4]
4. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
5. POL-DRD-001 Data Retention and Disposal Policy [SOC 2: CC6.5]
6. HIPAA Security Rule, 45 CFR §164.310

12 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release